

Relatorio Tecnico DevSecOps - Hemo Connect

Projeto: Hemo Connect

Integrantes: Marcos Zeller; Willian Donizetti

Instituicao: UMC

Ano: 2026

1. Introducao e contextualizacao

O Hemo Connect trata dados pessoais, credenciais derivadas, codigos temporarios de autenticao e registros de auditoria. A esteira DevSecOps verifica mudancas antes da integracao na branch principal e complementa os controles de autenticao, sessao, LGPD e auditoria existentes.

2. Ferramentas adotadas

TruffleHog analisa historico Git e arquivos rastreados para segredos verificados. Trivy realiza SCA nas dependencias Python e npm, bloqueando HIGH e CRITICAL. Semgrep OSS realiza SAST com os packs p/owasp-top-ten e p/cwe-top-25; findings ERROR bloqueiam a esteira.

3. Integracao com requisitos

A esteira reduz risco de exposicao de credenciais, CVEs em dependencias e padroes inseguros no backend FastAPI e frontend React. Ela complementa, mas nao substitui, os controles documentados de Argon2id, 2FA, sessao, recuperacao de senha, LGPD e auditoria.

4. Arquitetura da esteira

Developer -> Git push ou Pull Request -> GitHub Actions -> TruffleHog, Trivy e Semgrep -> validacao backend e frontend -> PASS para revisao ou FAIL com status check bloqueante.

5. Evidencias de funcionamento

Inserir prints reais apos executar a pipeline: workflow, jobs TruffleHog, Trivy e Semgrep, Job Green, checks do Pull Request e Ruleset ou Branch Protection da main. Este documento nao contem evidencias inventadas.

6. Politica de bloqueio

Segredo verificado: bloqueia sempre. Trivy: LOW e MEDIUM nao bloqueiam; HIGH e CRITICAL bloqueiam por exit-code 1. Semgrep OSS: INFO e WARNING nao bloqueiam; ERROR bloqueia por --error. O Ruleset da main deve exigir os status checks para impedir merge.

7. Resultados

Os resultados devem ser registrados somente apos uma execucao real no GitHub Actions. Identificar status de cada job, achados reais, impacto e recomendacao, sem expor credenciais ou tokens.

8. Conclusao

A esteira automatiza verificacoes de segredos, dependencias e codigo, criando uma barreira antes do merge. Ela nao garante seguranca absoluta; revisao humana, rotacao de segredos e correcao de achados permanecem obrigatorias.